

SECAUDIT 056 - SNAP SLAPPER high-bit / RAW release candidate

SECURITY AUDIT / PUBLIC REMEDIATION RECORD

Audit ID	SECAUDIT 056
Date	2026-09-15
Severity	CRITICAL overall. A user-opened SVG reaches a vendor-confirmed use-after-free in the pinned Qt line, and untrusted rasters reach native OpenImageIO decoders in-process without pre-decode resource ceilings or isolation. Three further HIGH release-integrity / executable-trust findings remain open.
Scope	The new Windows high-bit SNAP SLAPPER build, including 16-bit/float raster ingress and processing, external RawTherapee development, .slapper projects/artifact provenance, image layers, local/cloud generative fill, credentials/profiles, publishing handoff, and the onedir release artifact at dist-highbit/SNAP SLAPPER/.
Method	Two independent adversarial passes: Codex read and exercised the live tree and packaged artifact; Claude/"Erf" independently reviewed a separately supplied boundary/evidence brief, then the results were reconciled against live code. Static boundary tracing, dependency/advisory review, Authenticode/hash/ACL inspection, release-manifest audit, enabled-codec inventory, focused tests, and a packaged happy-path RAW launch. No exploit code.
Reporter	Codex (primary) + Claude/"Erf" (independent reviewer 2), requested by Sean.
Status	CLOSED FOR LOCAL BETA (2026-09-18). Every application-code finding is fixed and verified (see the two 2026-09-15 remediation sections and SECAUDIT 057, which re-verified the installed package). The one item that is not code - a Microsoft-recognised Authenticode certificate - is DROPPED, owner decision (Sean, 2026-09-18): "that is not ever happening." No third-party certificate will be purchased. Releases are signed with SnapSmack's own Ed25519 key (the mechanism the CMS updater / SMACKBACK already verify); Windows SmartScreen will warn on first run and that is documented, not fixed. Also still open as documented residual risk (not a finding): the decoder worker is a Job Object (memory/time/descendants), not a restricted-token/no-network sandbox.
Related	SECAUDIT 053-054 desktop duty-of-care/config boundaries; SECAUDIT 055 packaging integrity precedent.
Disclosure	Working .md only. PDF/signing/publication is Sean-gated after fixes and verification.

1. Summary

The high-bit conversion fixed the product requirement but widened the native-parser attack surface. The release candidate must not be distributed yet.

The most immediate release blocker is directly reachable: the build pins `PySide6==6.8.3` (`tools/hub/requirements.txt:7`), permits a user to add SVG image layers (`tools/hub/slapper_qt/layers_panel.py:411-416`), and sends those files to `QSvgRenderer` (`tools/hub/editor_engine.py:200-214`). Qt's advisory says the affected 6.8 range includes 6.8.3 and describes uncontrolled recursion and use-after-free vulnerabilities (CVE-2025-10728 / CVE-2025-10729, vendor score 9.4), fixed in 6.8.5 and later supported lines: <https://www.qt.io/blog/security-advisory-uncontrolled-recursion-and-use-after-free-vulnerabilities-in-qt-svg-module-impact-qt>.

The new OpenImageIO ingress is also not fail-closed. It decodes and materializes an arbitrary OIIO-supported image as float pixels before imposing the preview-size limit (`tools/hub/highbit_image.py:117-140`). The shipped plugin inventory includes EXR, TIFF, JPEG, BMP, Cineon, DDS, DPX, FITS, GIF, HDR, ICO, IFF, JPEG2000, PNG, PNM, PSD, RLA, SGI, Softimage, Targa, WebP and zfile. The application cannot realistically prove every native decoder safe, so it must constrain and isolate them.

The installed RawTherapee boundary is correctly external for licensing and maintenance, but executable discovery trusts `PATH` before installed locations and the native decoder runs at the user's full privilege. The release package itself is

unsigned and its directory is writable by Authenticated Users in the audited layout; an onedir application loads hundreds of adjacent DLLs. The generated SHA-256 manifest is useful inventory, but it is not signed and therefore cannot authenticate the package that contains both it and its verifier.

The independent reviewer ranked the unbounded OIIO boundary CRITICAL and additionally raised imported absolute artifact paths, cache poisoning, project ZIP traversal, and credential-to-AI exfiltration chains. Reconciliation confirmed the path and cache trust weaknesses, but found no member-name-based extraction, no project-driven arbitrary write, and no automatic AI egress. Those claims are narrowed below rather than repeated as established exploit chains.

2. Method and coverage

Review grounding

Primary review read the live implementations in:

- tools/hub/highbit_image.py, raw_preview.py, editor_engine.py, artifact_registry.py, gemini_image_edit.py, and audit_slapper_distribution.py;
- tools/hub/slapper_qt/layers_panel.py, local_fill.py, editor_window.py, and the publish/profile plumbing;
- tools/_shared/snap_imgsafe.py, snap_profiles.py, and snap_creds.py;
- the build requirements/spec, focused tests, package licences and generated dependency manifest.

The independent reviewer received the boundary descriptions and exact code facts separately and returned seven ranked findings. The primary pass then checked each against source. This satisfies independence but is not equivalent to a second live source checkout or penetration test; the missing hostile-file live tests remain OPEN.

Six chokepoints

1. **Untrusted image ingress - examined; OPEN.** OIIO, QtSvg, Pillow, RawTherapee, generated-image results, and project-carried images were traced. Findings F1, F2, F4, F7 and F8 apply.
2. **Config / manifest / profile ingestion - examined; partly inherited, partly OPEN.** Shared profiles reject a site_url that does not match the filename-derived site key (tools/_shared/snap_profiles.py:89-126), but unsigned package manifests and project-carried paths remain findings F3/F5/F6.
3. **JavaScript / IPC into desktop webviews - explicitly scoped out.** The audited editor is a native PySide window; the high-bit/RAW change introduces no webview or desktop JavaScript/IPC bridge. No close is claimed for other suite tools.
4. **Update & restore channel - examined; OPEN.** The exact candidate executable is unsigned, the manifest is unauthenticated, the audited onedir ACL permits modification, and project restore acts before full validation. Findings F3, F5 and F6 apply.
5. **Credential/token store at rest - examined; inherited control verified.** New writes are sealed through the shared vault and profile JSON omits credentials (tools/_shared/snap_creds.py:103-109, 228-232; tools/_shared/snap_profiles.py:132-172, 233-251). Changing this model remains three-way-sign-off territory. No new plaintext storage was found.
6. **Desktop -> CMS upload - examined at the desktop boundary; server parser not retested.** SNAP SLAPPER obtains the destination from a verified shared profile and the key from the vault (tools/hub/slapper_qt/editor_window.py:3209-3228, 3256-3300). The high-bit change does not create a new client-supplied URL or automatic upload. Server-side media parsing and mutual-auth remain inherited controls, not re-certified here.

Cross-cutting AI output was traced as data: cloud/local results become image pixels and are not treated as commands. Response/output size and local-runner integrity are nevertheless open (F7/F8).

Artifact checks

- Candidate: dist-highbit/SNAP SLAPPER/SNAP SLAPPER.exe
- SHA-256: 59B09E910AD970B239EBDF18B5E395181C80963BD56D4F6A6E1CC082D3C6EC94
- Authenticode: NotSigned
- RawTherapee CLI tested: C:\Program Files\RawTherapee\5.13\rawtherapee-cli.exe
- RawTherapee SHA-256: 9172A03896F0200DAF621909B024F6CD65A24837CAD56D0748730B2FA6D2FB6A
- RawTherapee Authenticode on this machine: NotSigned
- Distribution audit: passed, 366 files; required licences and manifest present.
- OpenImageIO runtime: 3.1.17.0. Its supported 3.1 line is current and 3.1.17 is newer than the PSD advisory's 3.1.16 fix floor: <<https://github.com/AcademySoftwareFoundation/OpenImageIO/security>> and <<https://github.com/AcademySoftwareFoundation/OpenImageIO/security/advisories/GHSA-3c8w-9xvm-r6gf>>.

Passing the package audit and opening a real ORF prove packaging and happy-path function only. They do not prove hostile parser containment.

3. Findings, ranked by reach

F1 - CRITICAL: vulnerable QtSvg is directly reachable through user-opened SVG layers

Evidence: tools/hub/requirements.txt:7; tools/hub/slapper_qt/layers_panel.py:411-416; tools/hub/editor_engine.py:200-214.

Failure mode: a crafted SVG selected as an image layer is parsed by Qt 6.8.3's affected SVG implementation, exposing the editor process to vendor-confirmed uncontrolled recursion and use-after-free conditions with native-code-execution potential.

Fail-closed fix: update PySide6/Qt to at least the vendor-fixed 6.8.5 (prefer the current supported patched line), and remove SVG from accepted inputs until the shipped runtime is verified. Add a packaged malicious/regression SVG corpus test and confirm the exact loaded Qt DLL version at runtime.

Status: OPEN - release blocker. Solo code update may be prepared, but closure requires build plus packaged live adversarial test.

F2 - CRITICAL: OpenImageIO decodes arbitrary supported formats in-process before any resource ceiling

Evidence: tools/hub/highbit_image.py:117-140. ImageBuf(path), reorientation and get_pixels(FLOAT) occur at lines 120-128; maximum is applied only after the full float allocation at line 140. Existing Pillow ingress limits are in tools/_shared/snap_imgsafe.py:53-65, 99-137, but this path bypasses them.

Failure mode: a crafted or extreme image can force excessive native decode/allocation in the full-privilege GUI process; a defect in any enabled OIIO codec reaches the same process without containment.

Fail-closed fix: preflight with ImageInput.spec() without materializing pixels; allowlist only intended photographic formats; enforce input bytes, width, height, channel count, per-sample size and total decoded bytes; reject exotic/unused codecs; decode in a restricted subprocess with memory, CPU and wall-time limits and no network. The parent accepts only a bounded, authenticated result.

Status: OPEN - release blocker. Closure requires malformed/extreme-file corpus tests against the shipped binary and verification that process/resource limits actually terminate the decoder.

F3 - HIGH: unsigned, writable onedir package permits false-green integrity and DLL planting

Evidence: the audited EXE is Authenticode NotSigned; the audited directory ACL grants Authenticated Users Modify. The build audit checks forbidden substrings in filenames and required filenames (tools/hub/audit_slapper_distribution.py:12-43), then writes an unsigned hash manifest into the same tree (:46-57). On the 2026-09-15 rerun, the audit reported success over 366 files but included its already-existing output manifest in files; its recorded self-hash was a9c210...e72a while the newly written file actually hashed to B7BEE2...0945. The manifest is therefore internally false immediately after a successful rerun.

Failure mode: modification of the executable or an adjacent DLL is not authenticated before execution; an attacker able to write the deployed folder can plant code, and can replace both files and their locally generated manifest. Independently, the current manifest generator emits a false-green success while producing an unverifiable self-entry.

Fail-closed fix: exclude the output manifest from its own payload inventory (or define a separately signed detached envelope) and add a post-write verifier that fails the build on any mismatch. Authenticode-sign the EXE/installer; publish a signed SBOM/manifest outside the mutable payload trust domain; verify signatures before launch/update; install under an administrator-owned, non-user-writable location; run a clean-machine installed-layout ACL and DLL-resolution test.

Status: CLOSED for the local beta (057 verified the protected ACL and 366/366 hashes). OWNER DECISION on the signing half, 2026-09-18: the "Authenticode-sign the EXE/installer" recommendation above is **REJECTED** - Sean: "we will sign it ourselves with our own key to our own satisfaction. we are not kissing microsoft's ass here." The distribution trust model is SnapSmack's own Ed25519 signature on the package, verified before launch/update by our own code (the mechanism the CMS updater and SMACKBACK already use), plus the protected install location. No Microsoft-recognised certificate will ever be purchased. Windows will show its first-run warning; that is documented to users, not treated as a defect. Still genuinely open: verify the self-signed installer/update path end to end on a clean machine.

F4 - HIGH: RawTherapee discovery trusts PATH, and the external native decoder is not contained

Evidence: tools/hub/raw_preview.py:24-40 returns shutil.which() before searching installed roots. It launches the result at :90-110 and :145-159 without a restricted token/job sandbox. The located 5.13 CLI on the audit machine is not Authenticode-signed.

Failure mode: a substituted executable earlier in PATH runs as the user; independently, a malicious RAW exercises RawTherapee's native parsers with the user's full process privileges.

Fail-closed fix: use an explicitly user-confirmed canonical installed path before any optional PATH fallback; bind the selected tool to recorded version/hash and warn on change (or verify a trusted publisher where available); run it in a restricted process with memory/CPU/time/network limits. Test PATH substitution and a hung/over-budget decoder against the packaged build.

Status: OPEN - release blocker. Tool-selection/signing policy requires three-way sign-off because it changes the external trust boundary.

F5 - HIGH: imported projects may cause local-file decoding before full document validation

Evidence: tools/hub/editor_engine.py:1810-1834 accepts source_path, uses it when it exists, and invokes RawTherapee for a RAW extension at lines 1829-1834; type/count/layer/history validation starts afterward at :1835-1875. Artifact records likewise normalize project-supplied paths without binding their content hash (tools/hub/artifact_registry.py:59-67, 147-160).

Failure mode: opening an untrusted .slapper can select an arbitrary existing local RAW path and cause external parsing/cache writes before the project has passed its complete schema and provenance checks. This is not a demonstrated arbitrary-file exfiltration or overwrite, but it is an untrusted-project-to-native-decoder action boundary.

Fail-closed fix: fully validate schema, numeric bounds, artifact graph and source ingredient first; refuse out-of-container absolute paths for imported projects unless the user explicitly re-links them; bind external sources to an expected content hash; only then call a contained decoder.

Status: OPEN. Three-way sign-off is required because project format/trust semantics and where personal source data comes to rest are involved; packaged hostile-project test required.

F6 - MEDIUM: project and RAW-development cache integrity is incomplete

Evidence: .slapper project JSON may be 512 MiB and is read into memory before parsing (tools/hub/editor_engine.py:84, 322-339, 1810-1813). Developed RAW cache hits are accepted on target/profile existence only (tools/hub/raw_preview.py:97-100), although fresh output is structurally decoded before atomic replace (:101-124).

Failure mode: a compact project can impose excessive memory/parse cost, and a same-user/user-writable-cache actor can replace a previously generated TIFF/profile that the editor then trusts without content/provenance verification.

Fail-closed fix: reduce the project-document ceiling to a realistic value, cap JSON nesting and ZIP compression ratio/count/aggregate, and store/verify a cache record binding source hash, normalized settings, producer version and output hash before every hit.

Status: OPEN. Format/provenance change requires three-way sign-off; hostile archive and cache-poison tests required.

F7 - MEDIUM: cloud generative-fill response has no body/base64 ceiling

Evidence: tools/hub/gemini_image_edit.py:113-134 buffers response.json(), base64-decodes inline image data and fully loads it before resizing. No Content-Length/body/decoded-byte ceiling is applied at this boundary.

Failure mode: a compromised/misbehaving endpoint or oversized response can exhaust memory before the image is reduced to the working crop.

Fail-closed fix: stream with a strict HTTP body ceiling, reject excessive base64 length before decode, and pass the result through a generated-image-specific format/dimension/decoded-byte allowlist before load.

Status: OPEN. Solo boundary fix plus regression test is sufficient; packaged live over-limit response test required.

F8 - MEDIUM: optional local-fill runner is an unverified executable boundary

Evidence: installed state is only three path-existence checks (tools/hub/slapper_qt/local_fill.py:16-30); the user-area Python and runner are executed directly (:54-80); the returned PNG is fully opened without a dedicated output-byte/dimension check (:81-89).

Failure mode: replacement of the user-writable runner/environment executes code when fill is requested, and a malformed/oversized result reaches Pillow without a tight local-output contract.

Fail-closed fix: integrity-bind the installed runner/environment to a signed installer manifest, display and verify updates, constrain the subprocess, and enforce a strict result file/format/dimension/byte contract.

Status: OPEN. Existing optional feature, but it ships as part of this editor's attack surface. Installer/signing policy requires three-way sign-off; output validation may be closed solo with tests.

4. Verified safe / narrowed findings

- **No shell/profile injection in RAW slider translation.** Adjustment values are converted to floats, clamped and formatted as numbers (tools/hub/raw_preview.py:65-87); RawTherapee receives an argv list with shell=False (:107-110, 156-159). This closes command-string injection for this path, not parser safety.
- **Fresh RAW outputs are checked before promotion.** The temporary TIFF receives a complete allowlisted Pillow decode before atomic replacement (tools/hub/raw_preview.py:101-124); preview JPEGs are also read through safe_open (:150-169). Cache-hit provenance remains F6.
- **No ZIP member-name write / demonstrated Zip Slip.** Embedded sources are copied from an exact member into an OS-created temporary filename, never to the member's path (tools/hub/editor_engine.py:342-371). The

reviewer-2 Zip Slip concern is therefore narrowed to archive resource ceilings and validation order, not arbitrary path extraction.

- **Embedded-source integrity is checked.** Extraction is streamed, capped at 512 MiB, SHA-256 checked when supplied, and a failed temporary is removed (`tools/hub/editor_engine.py:342-371`). The ceiling remains too broad for `project.json` and the hash is optional.
- **Artifact type graph rejects missing/cyclic sources and wrong consumer kinds.** `tools/hub/artifact_registry.py:70-160`. It does not authenticate project-supplied paths/content, which remains F5/F6.
- **AI output is data, not instruction.** Cloud output is converted to RGB pixels (`tools/hub/gemini_image_edit.py:128-138`); local output is pasted as pixels (`tools/hub/slapper_qt/local_fill.py:81-89`). No project-driven automatic egress or command execution was found, so reviewer 2's proposed F2->F7 exfiltration chain is not established.
- **Credentials are not newly written to profile JSON.** Shared-profile serialization omits credentials and migrates them to the sealed vault (`tools/_shared/snap_profiles.py:132-199, 233-251`); vault writes call `_seal` (`tools/_shared/snap_creds.py:103-109, 228-232`). This audit does not reopen the approved credential-at-rest architecture.
- **Bundled codec scope excludes RAW/video/GPL codec names.** Runtime OIIO inventory contains no RAW, HEIF or video plugin; `tools/hub/audit_slapper_distribution.py:12-43` rejects known forbidden filenames. This supports the licensing boundary, but filename checks cannot establish signed binary provenance (F3).
- **OpenImageIO version is on its supported 3.1 line and past the cited PSD fix.** This lowers known-CVE exposure; it does not replace containment or fuzzing.
- **Functional verification passed.** The focused release suite previously passed 34 tests, the package/licence audit passed again over 366 files, and the packaged editor remained alive while opening a real ORF. These are functional checks only.

5. Recommendations and open items

2026-09-15 overnight remediation completed

- **F1 mitigated in the packaged candidate:** PySide6/Qt was upgraded from 6.8.3 to 6.9.3 (`tools/hub/requirements.txt:7`). The rebuilt package contains `Qt6Core.dll 6.9.3.0`. F1 remains formally OPEN until the packaged hostile-SVG regression is run, per the audit process.
- **F2 partially mitigated:** `tools/hub/highbit_image.py` now rejects unsupported extensions, empty/over-1-GiB inputs, over-200-megapixel images, more than four channels, and float allocations over 2 GiB before `ImageBuf` pixel decode. Only BMP, GIF, JPEG, PNG, TIFF and WebP are admitted. Process isolation and hostile-format fuzzing remain OPEN.
- **F3 manifest truth bug closed:** `tools/hub/audit_slapper_distribution.py` excludes its output manifest from the payload list and performs a post-write size/hash verification of every entry. The rebuilt 367-file manifest does not list itself. Executable signing and protected installed ACL remain OPEN.
- **F4 partially mitigated:** known RawTherapee install roots now win over PATH, with a regression test proving a planted PATH binary loses. Hash/publisher confirmation, removal or confirmation of fallback, and restricted execution remain OPEN.
- **F5 partially mitigated:** project field types are now validated before source-path resolution or RawTherapee invocation (`tools/hub/editor_engine.py:1813-1839`), with a regression test proving malformed adjustments cannot trigger development. Imported absolute-path trust remains OPEN.
- **F7 boundary fix implemented:** Gemini is requested as a stream, HTTP bodies are capped at 64 MiB, inline decoded images at 32 MiB, formats at JPEG/PNG/WebP, and dimensions at 16 megapixels

(tools/hub/gemini_image_edit.py). Unit over-limit tests pass; the packaged hostile-response test remains OPEN.

- **Verification:** 35/35 focused hardening tests and 86/86 SNAP SLAPPER integration tests passed. The rebuilt candidate passed the 367-file distribution audit and an offscreen 16-bit TIFF packaged startup test. Candidate SHA-256: A8379756F7CF75CFC99CFC2D0443A56DA6947FD561CB571B57669F3873A440A5; location: dist-secure/SNAP SLAPPER/.
- **Dependency scan:** pip-audit 2.10.1 found no known vulnerabilities in the resolved tools/hub/requirements.txt dependency set after the Qt 6.9.3 upgrade. This closes the one-time scan item, not the requirement for an automated recurring build gate.

2026-09-15 continuation completed

- **F2 resource containment implemented:** high-bit raster materialization now occurs in a separate frozen worker (tools/hub/highbit_decode_worker.py; dispatch in tools/hub/run_slapper_qt.py) launched through a Windows Job Object (tools/hub/subprocess_limits.py) with a 2-GiB memory ceiling, 180-second timeout and kill-on-job-close. The worker independently repeats the format/size preflight and returns an allow-pickle-disabled NumPy archive; the parent revalidates shape, channel count and byte size. A valid packaged 16-bit TIFF decoded to (60, 80, 3) float32; a packaged unsupported PSD terminated by itself with status 2 and produced no output. **Residual:** the job is resource containment, not a restricted-token/AppContainer boundary; native decoder RCE remains able to act as the user while the worker lives.
- **F4 resource containment implemented:** RawTherapee preview and development now run through the same Job Object control with a 4-GiB memory ceiling, bounded timeout and descendant cleanup (tools/hub/raw_preview.py; tools/hub/subprocess_limits.py). **Residual:** publisher/hash pinning and restricted-token/no-network execution remain open.
- **F5 project action boundary fixed:** external project paths now raise ExternalProjectSourceApprovalRequired before filesystem access. The GUI names the exact path and defaults to No; only explicit approval retries with access. When the project records a source hash, it must match before decoding. Internal recovery explicitly trusts its own known source. Project type validation remains ahead of all source actions.
- **F5 archive hardening implemented:** .slapper archives now enforce a 16-MiB project-document cap, eight-entry cap, aggregate expansion ceiling and 200:1 compression ceiling, and reject absolute/traversal paths and Unix symlink members before reading. Crafted traversal and symlink regression tests pass.
- **F6 cache poisoning closed at the application boundary:** RAW preview/master/profile cache entries now carry an HMAC-SHA-256 record whose random per-install key is stored in the existing encrypted credential vault. A missing, modified or mismatched cache entry is decoded again and structurally validated instead of trusted. The planted-cache regression proves replacement is rejected and rebuilt.
- **F8 local runner boundary hardened:** the installed generative-fill runner must byte-match the runner bundled with the application, executes through a resource-limited Job Object, and may return only a <=32-MiB PNG no larger than 512x512. A modified runner is no longer considered installed.
- **Final verification:** 43/43 focused security tests and 86/86 SNAP SLAPPER integration tests passed. pip-audit remains clean. The corrected distribution audit passed over 371 files. Packaged Qt is 6.9.3.0. The final frozen application passed the offscreen 16-bit editor startup gate even while the old installed instance remained open; its valid worker returned 0, and the unsupported-file worker returned 2 without a dialog or output. Final candidate SHA-256: CB3FEAD11281623C5B32DC78E8A0066683A47C89E4AB50AC66B21B62AF3C4203; location: dist-secure/SNAP SLAPPER/.
- **Signing fact:** neither Current User nor Local Machine certificate stores contain a code-signing certificate with a private key. The candidate remains Authenticode NotSigned. *(Original wording continued "this cannot be honestly closed ... with a self-signed certificate" - that framed Microsoft's trust store as the only valid publisher identity. Owner decision*

2026-09-18: it is not. SnapSmack signs its own releases with its own Ed25519 key and verifies them with its own code; the Authenticode line is closed as REJECTED, not as unmet.)

- **Recurring dependency gate implemented:** tools/hub/build.bat installs pinned pip-audit==2.10.1, audits the resolved application requirements, and aborts before packaging on any known vulnerability.

Release sequence, in security order:

1. **Immediately remove SVG input or upgrade Qt/PySide and verify the loaded packaged DLLs (F1).**
2. **Put all untrusted native decoding behind strict preflight ceilings and a restricted subprocess;** trim OIIO formats to the product contract (F2/F4).
3. **Define and implement the signed Windows distribution trust model** - (was: Authenticode-signed executable/installer) **SnapSmack-Ed25519-signed package + signed manifest, verified by our own installer/updater before launch/update; protected install ACL (done, 057). Owner decision 2026-09-18: no third-party certificate.** (F3)
4. **Move complete project validation ahead of all file/decode actions; define portable/re-linked project-source semantics (F5/F6).**
5. **Bound cloud/local AI result bytes and integrity-bind the optional local runner (F7/F8).**
6. Keep the new build-time pip-audit gate current and monitor vendor advisories for native components that Python package databases do not cover.
7. Run the missing packaged adversarial suite: malicious SVG regression, malformed/extreme images for every enabled codec, memory/time termination, PATH substitution, hostile project/re-link, cache poisoning, oversized Gemini response, local-runner replacement, clean-machine ACL/DLL resolution, and rollback off the happy path.

The security architecture/signing/project-format decisions are three-way items (Sean + Claude + Codex). Straight boundary checks with no format/trust-policy change may be implemented and closed solo only with regression tests and packaged live verification.

6. Closure checklist

- [x] Audit number checked: 056 follows 055.
- [x] All six chokepoints examined or explicitly scoped out.
- [x] Two independent adversarial reviewers used and cross-checked.
- [x] Severity disagreements and unsupported chains reconciled in this report.
- [x] Findings and safe conclusions cite live code.
- [x] Findings ranked by reach to code execution / data compromise.
- [x] No asking-side control counted as an enforcing close.
- [x] Code-execution controls without packaged adversarial proof remain OPEN.
- [x] Sign-off tier assigned to open work.
- [x] No exploit code produced.
- [] F1 QtSvg exposure removed/upgraded and packaged hostile-SVG test passed.
- [] F2 OIIO preflight/allowlist/isolation implemented and hostile corpus passed.
- [x] F3 protected installed distribution verified (057: ACL locked, 366/366 hashes) · Authenticode **REJECTED by owner 2026-09-18** (self-signed with SnapSmack's Ed25519 key instead)
- [] F3 self-signed installer/update path verified end to end on a clean machine
- [] F3 manifest self-entry removed/redesigned and a post-write full verification passes.

- ☐ F4 RawTherapee selection and containment verified under substitution/resource tests.
- ☒ F5 external-path approval plus traversal/symlink archive tests passed.
- ☒ F6 HMAC cache-provenance and planted-cache rejection test passed.
- ☒ F7/F8 AI response/runner boundaries constrained; over-limit/tamper tests passed.
- ☒ Automated transitive Python dependency scan enabled in the build gate; one-time result clean.
- ☐ Rollback tested off the happy path.
- ☒ Sean approved publication 2026-09-18 (buzzers + site PDF).